

Datenschutz: Grundrecht auf informationelle Selbstbestimmung. Schützt Bürger bei Machtungleichgewichten.

DSGVO: Datenschutz = Schutz von Menschen, nicht von Unternehmen (juristische Personen)!

Art. 2 DSGVO = Wann gilt DSGVO? Wenn alle Bedingungen erfüllt:

1. **Personenbezogene Daten** = Informationen über identifizierte oder identifizierbare (Zusatzinfos nötig) Person.
2. **Verarbeitung** = **Art. 4 DSGVO Was gilt als Datenverarbeitung?** (praktisch alles).
3. **Dateisystem** → strukturierte Sammlung personenbezogener Daten.
4. **Keine Ausnahme** → Privat: Familie & Freunde.
5. **Räumliche Anwendbarkeit** → Verantwortlicher oder betroffene Personen in der EU = Marktortprinzip.

Art. 5 DSGVO = Wie verarbeiten? Abs. 1 =

1. **Rechtmäßigkeit** (Art. 6) + **Treu und Glauben** + **Transparenz**
2. **Zweckbindung**
3. **Datenminimierung**
4. **Richtigkeit**
5. **Speicherbegrenzung**
6. **Integrität und Vertraulichkeit**

Abs. 2 = **Rechenschaftspflicht**: Verantwortlicher muss Einhaltung beweisen können.

Art. 6 DSGVO = Darf verarbeiten? Art. 5 & Art. 6 immer prüfen.

a) **Einwilligung**: **Art. 7 DSGVO = Wann Einwilligung gültig?** ⇔ freiwillig ∧ informiert ∧ zweckgebunden ∧ aktiv(sign, click) ∧ nachweisbar ∧ widerrufbar.

Koppelungsverbot: Einwilligung erzwungen. Verboten: „Du bekommst X nur, wenn du auch Y erlaubst“.

- b) **Vertragserfüllung**
- c) **Rechtliche Verpflichtung**
- d) **Lebenswichtige Interessen**
- e) **Öffentliche Aufgabe**
- f) **Berechtigtes Interesse**

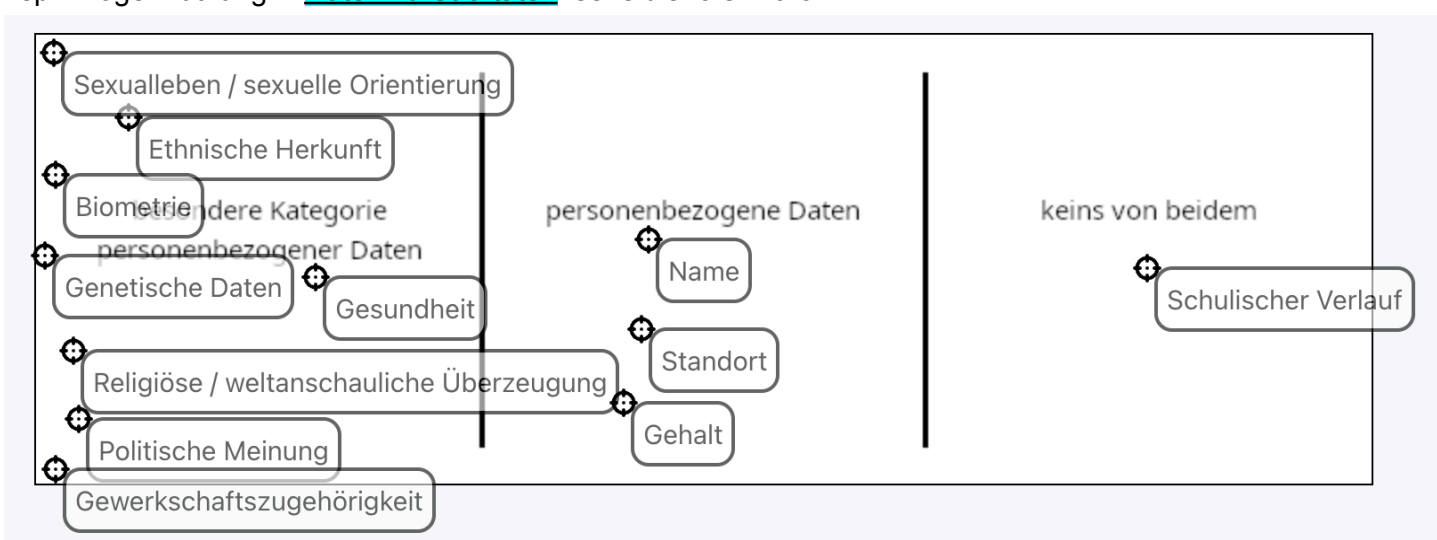
Berechtigt? z.B: Betrugsprävention; Nicht für Gewinnmaximierung.

Erforderlich? Gibt es milderes Mittel?

Interessenabwägung: Überwiegt Datenschutz oder Interesse des Verantwortlichen (Unternehmen)?

Art. 9 DSGVO = Besonders schützenswerte Daten = zu Benachteiligung, Diskriminierung und Verfolgung führen können.

Bsp: Drogennutzung... **Daten zu Straftaten**: sensibler als Art. 9.



Rechtsgrundlagen-Mix: Eine Verarbeitung ⇒ mehrere Rechtsgrundlagen. z.B: Online-Shop:

Konto → Einwilligung

Bestellung → Vertragserfüllung

Rechnung → Rechtliche Verpflichtung

Werbung → Berechtigtes Interesse

Art. 12–22 DSGVO = Informationsrechte + Eingriffsrechte:

Information (Art. 12–14) (ohne Nachfrage) Art. 13: Daten direkt erhoben. Art. 14: Daten von Dritten.

Auskunft (Art. 15) = Informationsrecht (auf Nachfrage) Beschwerderecht.

Berichtigung (Art. 16)

Löschung (Art. 17) wenn kein Löschhindernis besteht (z. B. Zweck entfällt, Einwilligung widerrufen)

Einschränkung (Art. 18) **Verarbeitung eingeschränkt**, z. B. während Prüfung von Widerspruch.

Datenübertragbarkeit (Art. 20) **Anbieterwechsel erleichtern**. Einwilligung/Vetrag. Bei Fotos, Kontaktliste; digital möglich.

Widerspruch (Art. 21) führt zu Interessenabwägung. Immer bei Direktwerbung.

Risikostufen (CNIL-Modell) Dimensionen: Risk = Schaden × Wahrscheinlichkeit.

Schadensarten: Körperlich. Materiell (Besitz). Moralisch (Diskriminierung).

Vernachlässigbar → kleine Unannehmlichkeit

Begrenzt → spürbar, aber überwindbar z.B: leichte Erkrankung

Bedeutend → ernsthafte Folgen, nur mit Mühen überwindbar z.B: Unfall, Diskriminierung.

Maximal → unüberwindbar z.B: Tod, lebenslange Verfolgung.

Öffentlich egal? Nein: Manuell ansehen ≠ systematisch sammeln ⇒ neue Risiken entstehen.

Art. 35 Abs. 1 DSGVO = Wann ist eine DSFA Pflicht? Wenn hohes Risiko besteht.

EDSA Kriterien = Wann ein hohes Risiko?

Profiling?

Automatisierte Entscheidungen?

Systematische Überwachung öffentlicher Bereiche?

Besonders schützenswerte Daten? (Art. 9)

Großer Umfang?

Datenverknüpfung?

Schutzbedürftige Personen? → Kinder, Beschäftigte, Patienten

Neue Technologien? → z. B. Gesichtserkennung

Wird Auskunft/Löschung verhindert?

Ablauf einer DSFA (Datenschutz-Folgenabschätzung)

1. **Vorprüfung**

2. **Verarbeitung verstehen**

3. **Risiken einschätzen**

4. **Gegenmaßnahmen planen** → Risk minimieren

Ergebnis dokumentieren (Pflicht)

Art. 25 DSGVO = Datenschutz von Anfang an Art. 5. Design: „Du kannst nicht“. Policy: „Du darfst nicht“. Design > Policy.

Abs. 1: Data Protection by Design **Datenschutz durch Technikgestaltung**. Typische Bsp: Trenne Identität & Inhalt,

Pseudonymisierung. **Wer?** Verantwortlicher. **Wann?** bei Planung + während der gesamten Verarbeitung.

Tor-Browser Datenschutz by Design. Schutzmechanismen: Onion Routing (Quelle & Ziel getrennt). HTTPS by Default.

JavaScript-Blocked. Anti-Fingerprinting. Automatisches Löschen am Session-Ende.

Grenzen: Nutzung wirkt verdächtig. Login hebt Anonymität auf. Missbrauch möglich (Darknet).

Abs. 2: Data Protection by Default **Datenschutz durch Voreinstellungen**. Standard beschränken (Nutzer erweitern aktiv):

1. **Daten minimal**. z. B. kein Geburtsdatum, wenn Alter reicht

2. **Verarbeitungsumfang minimal**. z. B. kein Tracking ohne Aktivierung

3. **Speicherfrist minimal**. z. B. automatische Löschung

4. **Zugriff nur für Berechtigte**. z. B. kein öffentliches Profil

Art. 32 DSGVO = Technische und organisatorische Maßnahmen (TOMs) for CIA

Berücksichtigung bei der Auswahl: Stand der Technik, Kosten, Umfang, Umstände, Zweck der Verarbeitung, Risiko. **Bsp**

für TOMs: Vers., Pseudonymisierung, Backups, Berechtigungskonzepte (Zugriffskontrollen) => Vertraulichkeit & Integrität.

Trainingsverfahren für Machine Learning

Federated Learning: Training dezentral auf Geräten. Daten bleiben lokal. Nur Modell-Updates gehen an Server.

Differential Privacy: Rauschen: Einzelnen Punkten unklar. Durch Bildung des Durchschnitts wird Rauschen eliminiert. Bsp: Ja/Nein Befragung: Zufällig Antworten flippen. Der Durchschnitt bleibt gleich. DSGVO-Risiko niedrig.

Datenschutz-Schutzziele:

Nicht-Verkettbarkeit: Datenverknüpfung aus verschiedenen Quellen → Profil entsteht.

Intervenierbarkeit: Eingreifen: Auskunft, Berichtigung, Löschung, Widerspruch.

Art. 88 DSGVO = erlaubt nationale Sonderregeln für Arbeit.

BDSG § 26 = Wann Arbeitgeber Daten verarbeiten? Nur wenn erforderlich. (Art. 88 DSGVO in DE)

Erforderliche Zwecke: Lohnabrechnung, Arbeitszeiterfassung, Urlaubsverwaltung, Einsatzplanung, IT-Sicherheit.

§ 26 Abs. 1: **Straftaten** nur bei konkretem Verdacht, dokumentierten Tatsachen.

§ 26 Abs. 2: **Einwilligung als Arbeitnehmer ist Ausnahme:** echter Vorteil für Arbeitnehmer oder gleichgelagerte Interessen.

Bsp: Foto für Firmenwebsite ❌. Foto für Betriebsausweis ⚠️ möglich.

BetrVG = Sobald Überwachungsgerechte Technik existiert (Nutzung egal), gilt **Mitbestimmungspflicht**.

Technik: Zeiterfassung, Videoüberwachung, Zutrittskarten, Leistungsstatistiken, Call-Center-Aufzeichnungen...

Kollektivvereinbarung: Vertrag nicht zwischen Einzelnen, sondern für ein Kollektiv. Ersetzt Einzel-Einwilligungen. Bsp: BV.

Betriebsvereinbarung (BV): Kollektive Regelung zwischen Arbeitgeber & Betriebsrat Inhalte: Zweck der Datenerhebung.

Welche Daten? Wer darf zugreifen? Wie lange speichern? Welche Auswertungen erlaubt? Transparenz für Beschäftigte.

Art. 88 Abs. 2 = **Grenzen der Kollektivvereinbarungen:** BV darf Grundrechte nicht verletzen. Keine Totalüberwachung.

Bsp: Call-Center-Aufzeichnungen: § 201 StGB (Verbot der unbefugten Aufzeichnung) + DSGVO + Mitbestimmung.

Nur mit Information, Zweckbindung, begrenzter Auswertung und BV zulässig.

Rechte von Betriebsrat

Mitbestimmung = blockieren/erlauben bei Maßnahmen zur Leistungs-/Verhaltenskontrolle, Fragebögen, Beurteilungsgrundsätzen und Auswahlrichtlinien.

Mitwirkung = Mitreden. Information, Beratung, Anhörung & Widerspruch bei Kündigung, Vorschlag (Personal, Ausbildung).

Unternehmen wollen: viele Daten sammeln + Datenweitergabe notwendig (an Dritte): Lieferando.

Berechtigung durch Art 6 DSGVO. Normalfall: Vertrag.

Adresse → Lieferung ✓ → Werbung ❌ (extra Rechtsgrundlage nötig).

HGB = **Aufbewahrungspflicht:** Rechnungen & Belege müssen 8 Jahre gespeichert werden. (rechtliche Verpflichtung).

Direktwerbung: Art 6. DSGVO → **Darf ich Daten für Werbung nutzen?** + UWG § 7 → **Darf ich jemanden damit belästigen?**

Erwägungsgrund 47 DSGVO = **Direktwerbung kann berechtigtes Interesse sein** → Interessenabwägung nötig.

UWG 7 Abs. 3 = **Ausnahme für Direktwerbung** (alle 4 nötig!)

E-Mail beim Verkauf erhalten.

Werbung für ähnliche Produkte.

Kein Widerspruch.

Hinweis auf Widerspruch bei Erhebung + jeder Mail.

Double-Opt-In Einwilligungsverfahren zur E-Mail-Werbung:

Einwilligung + Info

E-Mail eingeben (Problem jeder kann die Emailadresse eintragen.)

Bestätigungs-Mail

Klick auf Link (2. Zustimmung)

Art. 4 Nr. 12 DSGVO = **Meldepflicht bei Datenschutzverstößen**. Verletzung der Sicherheit mit: Verlust, Vernichtung, Veränderung, unbefugtem Zugriff/Offenlegung.

Zweistufige Meldepflicht

Art. 33 DSGVO = **Meldepflicht an die Aufsichtsbehörde**: Frist: 3 Tage.

Keine Meldung, wenn: Voraussichtlich kein Risiko für Rechte/Freiheiten.

Art. 34 DSGVO = **Meldepflicht an Betroffene**: Wenn hohes Risiko.

Keine Meldung, wenn: Daten verschlüsselt. Maßnahmen haben Risiko beseitigt.

Art. 10 GG = **Fernmeldegeheimnis** = Schutz der Vertraulichkeit der Kommunikation für Absender & Empfänger.

§ 3 TDDDG = Konkretisiert Art. 10 GG in DE. Anbieter muss schützen:

Inhalte, Metadaten (wer, wann, wie oft). Schutzobjekt = Natürliche Personen + vertrauliche Kommunikation.

OTT-Dienste (Over-the-Top) = Kommunikationsdienste über Internet (z. B. WhatsApp).

§ 206 StGB = **Verletzung des Fernmeldegeheimnisses** = **Straftat**. Verboten: Offenlegen, Öffnen, Unterdrücken.

§ 25 Abs. 1 TDDDG = **Zugriff auf Endgerät nur mit Einwilligung**. Einwilligung für digitalen Diensten ≠ Einwilligung für Datenverarbeitung (Art 6 zusätzlich überprüfen).

Tracking (Zugriff auf Endgerät) = Webseiten; Nutzer wiederzuerkennen. Cookies, IP-Adresse usw. Ablehnen ermöglichen.

- 1 = Kein Tracking
- 0 = Tracking erlaubt
- „/NULL → Keine Präferenz

§ 25 Abs. 2 TDDDG = **Keine Einwilligung nötig, wenn technisch erforderlich**. WhatsApp → Übertragung von Nachrichten.

Art. 26 DSGVO = **Gemeinsame Verantwortlichkeit** = Mehrere entscheiden gemeinsam über Zweck & Mittel.

Bsp: Website + Facebook-Like-Button

Art. 4 Nr. 4 DSGVO = **Was ist Profiling?** = Automatisierte Auswertung personenbezogener Daten → Prognose.

Profiling arbeitet mit Gruppen, nicht mit Individuen. Bsp: Menschen mit X Merkmale...

Profiling ist erlaubt (wichtig für Wirtschaft).

Bsp: Kreditscoring (z. B. SCHUFA) Ziel: Zahlungsausfallrisiko senken.

Score = keine Tatsache, sondern statistische Prognose (Wahrscheinlichkeit).

Art. 22 DSGVO = **Automatisierte Entscheidung verboten, wenn:** (EuGH-Argumentation)

ausschließlich automatisiert + rechtliche/erhebliche Wirkung.

Art. 44 DSGVO = **Drittlandübermittlung** nur, wenn Schutz erhalten bleibt.

Prüfung:

1. **Art. 6 Rechtsgrundlage?**
2. **Art. 45 = Angemessenes Schutzniveau?** EU bestimmt.
3. **Art. 46 = Geeignete Garantien?** Vertraglich.
4. **Art. 49 = Ausnahmen** in Einzelfällen + nicht dauerhaft.

Ausnahmen: Einwilligung, Vertrag, öffentliche Interessen, Rechtsansprüche, lebenswichtige Interessen, Einzelfallabwägung (sehr eng).

Art. 28 = **Auftragsverarbeitung**: Verantwortlicher bleibt verantwortlich, Auftragsverarbeiter haftet für eigene Fehler.

Typische-Mini-Fälle

- IP-Adresse mit Zeitstempel → personenbezogen ✓
- Mitgliederliste Verein → DSGVO ✓
- Fitness-App mit Account → personenbezogen ✓
- Aggregierte Statistik → meist anonym ✓
- Newsletter ohne Info → Transparenz ✗
- Daten für neuen Zweck → Zweckbindung ✗
- Zu viele Pflichtfelder → Datenminimierung ✗
- Alte Kundendaten ewig gespeichert → Speicherbegrenzung ✗
- Kein Zugriffsschutz → Integrität/Vertraulichkeit ✗
- Keine Doku → Rechenschaftspflicht ✗
- Bewusstlose Person + Krankenkassenkarte → Art. 6 Abs. 1 lit. d ✓
- Weihnachtsgeschenk Arbeitgeber → Vertrag / berechtigtes Interesse ✓
- Hotel verrät Übernachtung → Datenschutzverstoß ✗